

INTEGRATE ZSCALER WITH IDENTITY
PROVIDERS (IDPS)
SUCH AS AZURE AD, OKTA AND
ACTIVE DIRECTORY FOR SEAMLESS
AUTHENTICATION AND
AUTHORIZATION

Project details

Title: Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

This project explains how we plan to connect the Zscaler security platform with our organization's main identity systems: Microsoft Entra ID (Azure AD), Okta, and on-premises Active Directory (AD). The goal is to create a smooth, secure, and automatic system for verifying and managing user access across all Zscaler services.

By using these centralized identity systems instead of separate local accounts, we can build a true Zero Trust model, where access is always checked based on who the user is and the situation. This setup will let us have one main source for authentication, apply consistent security rules like Multi-Factor Authentication (MFA), and make login easier through Single Sign-On (SSO).

The main purpose of this project is to integrate the Zscaler security platform with key Identity Providers (IdPs) such as Microsoft Entra ID (Azure AD), Okta, and on-premises Active Directory (AD). By doing this, the project aims to create a centralized, secure, and automated system for user authentication and authorization across all Zscaler services.

Currently, organizations often manage multiple separate accounts for different systems, which can be confusing and less secure. This project addresses that by using centralized identity providers, ensuring that access is continuously verified based on user identity and context, following a Zero Trust model. The integration also enables Multi-Factor Authentication (MFA) to improve security and Single Sign-On (SSO) to simplify the login process. Overall, this project ensures that the right users get the right level of secure access to applications and the internet, regardless of their location, while reducing administrative overhead and improving user experience.

Abstract:

The project **“Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization”** focuses on connecting the Zscaler security platform with key identity systems to create a secure, automated, and easy-to-use authentication framework. The main goal is to centralize user management, enforce consistent security policies, and simplify login across all Zscaler services.

Integrating Zscaler with Identity Providers like Microsoft Azure Active Directory, Okta, and Active Directory helps organizations manage user login and access in a secure and simple way. This integration allows users to log in once and securely access different applications and internet services without logging in multiple times.

By using authentication methods such as Single Sign-On (SSO) and protocols like SAML, Zscaler verifies the user’s identity through the identity provider before allowing access. This improves security by ensuring that only authorized users can access company resources.

It also helps administrators easily manage user accounts, permissions, and security policies from a central system. Overall, integrating Zscaler with identity providers improves security, simplifies the login process for users, and supports modern Zero Trust security practices.

Additionally, the integration helps IT administrators manage user identities, roles, and permissions from a single platform, reducing administrative overhead and improving compliance. It also supports Zero Trust architecture, where every access request is continuously verified based on user identity, device posture, and context.

Use Case Scenarios:

Use Case Scenario 1: Single Sign-On (SSO) Authentication

In many organizations, employees need to access multiple cloud applications, internal systems, and the internet. Without identity integration, users must log in separately to each application. By integrating Zscaler with Identity Providers such as Microsoft Azure Active Directory, Okta, or Active Directory, the organization can implement **Single Sign-On (SSO)**.

When a user tries to access the internet or a cloud application through Zscaler, Zscaler redirects the authentication request to the Identity Provider. The IdP verifies the user credentials and sends an authentication token back to Zscaler.

Output

- User logs in only once using corporate credentials.
 - Zscaler receives authentication confirmation from the IdP.
 - The user can access approved applications and internet resources without repeated logins.
 - User experience improves while maintaining strong security.
-

Use Case Scenario 2: Student Access to Library Resources

A graduate student is working off-campus and needs access to licensed academic journals and databases hosted on the university's internal network. Instead of connecting through a full VPN tunnel, **Zscaler Private Access (ZPA)** provides direct access to the library application portal. The student logs in through the university's identity provider, ensuring that only enrolled students can access subscription-based content.

Output

- **User Identity Verified:** The student is recognized as part of the `Enrolled_Student_Group`.
- **Access Scope Defined:** Access is limited to the Library Portal and authorized journal databases.
- **Policy Enforcement:** Only authorized users can access content, preventing credential sharing.
- **User Experience:** Single Sign-On (SSO) allows seamless access without the complexity of a VPN client.
- **No Broad Network Access:** The student cannot access administrative systems or other internal servers.

Use Case Scenario 3: HR Administrator Access to Payroll System

An HR administrator needs to access the payroll system to process monthly salaries. Due to the sensitive nature of payroll data, access must be restricted to specific working hours and require additional verification. The administrator logs in through the organization's identity provider, and **Zscaler Private Access (ZPA)** enforces time-based restrictions and Multi-Factor Authentication (MFA) policies.

Output:

- **User Identity Verified:** The administrator is part of the `HR_Payroll_Group`.
 - **Time-Based Restriction:** Access is allowed only during business hours (8:00 AM – 6:00 PM).
 - **Step-Up Authentication:** MFA is triggered when accessing the payroll application.
 - **Connection Restricted:** The administrator can only access the Payroll Application Server.
 - **Audit Trail:** Full session logs are maintained to meet compliance requirements.
-

Use Case Scenario 4: IT Helpdesk Remote Troubleshooting

An IT support technician needs to troubleshoot a server issue while working from home. Instead of giving broad network access, **Zscaler Private Access (ZPA)** provides **Just-in-Time (JIT) access** to the specific server that requires maintenance. The technician authenticates through the organization's identity provider, and administrative privileges are granted only for the duration of the task.

Output:

- User Identity Verified: The technician belongs to the IT_Helpdesk_Group.
- Just-in-Time Access: Admin rights are elevated only for the active troubleshooting session.
- Connection Restricted: Access is limited to the specific target server (Server-X).
- Privilege Boundaries Enforced: The technician cannot access other infrastructure components like databases or domain controllers.
- Session Monitoring: Real-time activity logging is maintained for security review.

Use Case Scenario 5: Contractor Access to Project Management Tool

An external project manager, hired for a specific initiative, needs access to the university's project management tools, such as Jira or SharePoint. Instead of providing broad network access, **Zscaler Private Access (ZPA)** grants **time-limited access** that automatically expires when the contract ends. The contractor logs in through the university's identity provider, and access is provisioned based on group membership synchronized from Azure AD.

Output:

- User Identity Verified: The contractor is part of the External_Contractor_Group.
 - Time-Bound Access: Access automatically ends after the contract's completion date.
 - Connection Restricted: Access is limited only to the Project Management Application.
 - Segmentation Enforced: The contractor cannot view or access internal resources such as finance systems or student databases.
-

Stage-1

Title of the Project:

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution.

Overview:

The project “Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization” focuses on creating a secure, centralized, and automated system for user authentication and authorization.

Traditional VPN systems were widely used in organizations to allow employees to securely connect to company networks from outside locations. However, these **legacy VPN architectures** have several limitations such as complex management, slower performance, and higher security risks. Once a user logs in through a VPN, they may get broad access to the internal network, which can expose sensitive data if the account is compromised.

Another advantage of replacing VPN with Zscaler is improved performance and flexibility. In traditional VPN setups, all user traffic must pass through the company’s data center, which can slow down internet speed and create network congestion. With Zscaler’s cloud-based platform, users can directly connect to applications and the internet securely from anywhere without routing traffic through the corporate network. This makes it easier for organizations to support remote work and hybrid working environments.

Overall, modernizing legacy VPN systems with a Zscaler Zero Trust solution helps organizations improve security, simplify network management, and provide faster access to applications. It reduces security risks by limiting access only to necessary resources and continuously verifying users. This approach helps companies build a secure and scalable network infrastructure that supports modern business needs.

List of teammates

S.NO	NAME	COLLEGE	CONTACT
1	Sugan A	Shree venkateshwara College of Arts and Science	sugana2023aids@gmail.com
2	Jesudass S	Shree venkateshwara College of Arts and Science	Jesudasss2023aids@gmail.com
3	MohammadsameemM	Shree venkateshwara College of Arts and Science	Mohammadsameemm2023aids@gmail.c0m
4	Mohamed Vasim khan H	Shree venkateshwara College of Arts and Science	vasimvasimm661@gmail.com
5	Kasan khan S	Shree venkateshwara College of Arts and Science	Kasankhans2023aids@gmail.com

List of Vulnerability Table:

S.NO	CATEGORY NAME	VULNERABILITY NAME	CWE/CVE - NO
1	Broken Access Control	Unverified Ownership	CWE-283
2	Security Misconfiguration	Configuration	CWE-16
3	Software Supply Chain Failures	Reliance on Insufficiently Trustworthy Component	CWE-1357
4	Cryptographic Failures	Small Space of Random Values	CWE-334
5	Injection	Improper Input Validation	CWE-20

6	Insecure Design	Protection Mechanism failure	CWE-693
7	Authentication Failures	Reliance on IP Address for Authentication	CWE-291
8	Software or Data Integrity Failures	Untrusted Search path	CWE-426
9	Security Logging & Alerting Failures	Insufficient Logging	CWE-778
10	Mishandling of Exceptional Conditions	Unchecked Error Condition	CWE-391

REPORT

1. Vulnerability Name:

Exposure of Sensitive Information to an Unauthorized Author

OWASP Category: OWASP Top 10-Broken Access Control

Description:

This vulnerability occurs when sensitive or confidential information is inadvertently exposed to users, systems, or applications that do not have proper authorization to access it. Sensitive information can include personal data, credentials, financial details, proprietary business data, or system configuration information. Exploitation of this vulnerability may allow unauthorized actors to view, copy, or misuse the information, potentially leading to identity theft, financial loss, data breaches, or compromise of system integrity.

Business Impact:

Exposure of sensitive information to unauthorized actors can have severe consequences for a business, including financial losses, reputational damage, and legal or regulatory penalties. Confidential data such as personal information, financial records, or proprietary business information may be stolen or misused, leading to operational disruptions and loss of customer trust. Additionally, leaked intellectual property or business strategies can give competitors an advantage, further impacting the organization's competitiveness and long-term stability.

Recommendation/Mitigation:

- Regularly audit identity providers (Azure AD, Okta, Active Directory) to ensure only authorized users have access.
- Enforce Multi-Factor Authentication (MFA) for all users, especially remote users.
- Implement Role-Based Access Control (RBAC) to assign permissions based on job roles.
- Use Just-in-Time (JIT) access for sensitive tasks to reduce exposure.
- Enable Single Sign-On (SSO) to simplify login while maintaining strong security.
- Continuously monitor user activity and maintain audit logs.
- Keep Zscaler and identity provider integrations updated with security patches.

Mitigation Strategies:

- Prevent unauthorized access with MFA, SSO, and RBAC.
 - Reduce credential sharing or theft using automated provisioning and deprovisioning (SCIM).
 - Limit lateral movement by restricting access to specific servers or applications.
 - Protect off-network access by verifying user location, device compliance, and access time.
 - Prevent data leakage with encryption, session monitoring, and activity logging.
 - Maintain compliance through regular audits and detailed reporting.
-

2. Vulnerability Name: Active Debug Code

CWE/CVE: CWE-489

OWASP/SANS Category: OWASP Top 10- Security Misconfiguration

Description:

Active Debug Code vulnerability occurs when debugging or development features remain enabled in a production environment. During application development, developers often include debug messages, test endpoints, stack traces, or debugging scripts to help identify and fix errors. If these debugging components are not removed or disabled before deployment, attackers may exploit them to gain sensitive system information.

Debug information can reveal internal details such as application logic, system configuration, file paths, database queries, or server environment variables. Attackers can use this information to understand how the system works and identify additional vulnerabilities. Leaving debug code active increases the risk of information disclosure and may allow attackers to bypass security controls or perform unauthorized actions.

Business Impact:

Leaving active debug code in a production environment can create serious business risks. Debug code often exposes internal system logic, configuration details, or sensitive data, which can be exploited by attackers to bypass security controls or gain unauthorized access. This can lead to data breaches, financial loss, operational disruption, and reputational damage. Additionally, the presence of debug code may reveal vulnerabilities to competitors or malicious actors, increasing the likelihood of targeted attacks and regulatory non-compliance.



Knowing the weaknesses that result in vulnerabilities means software developers, hardware designers, and security architects can eliminate them before deployment, when it is much easier and cheaper to do so

Learn About CWE		
Overview – Learn what CWE is and how to use the information available on this website		Root Cause Mapping – Learn about identifying the underlying cause(s) of a vulnerability
Basics FAQs Glossary		Guidance Quick Tips Examples
Access Content	Contribute	Latest News and Updates
All Weaknesses (944 total) Top-N Lists Search CWE ENHANCED BY Google View CWEs by	Contribute CWE Content Participate in Working Groups	News "2025 CWE Top 10 KEV Weaknesses" List Now Available News "2025 CWE Top 25 Weaknesses "On the Cusp" List Now Available News CWE Version 4.19.1 Now Available News "2025 CWE™ Top 25" Now Available!

Recommendation/Migation:

- Remove all debug or test code before deploying to production.
- Replace debug prints with secure logging mechanisms that mask sensitive data.
- Conduct thorough code reviews to detect leftover debug code.
- Restrict access to development and staging environments.
- Implement role-based access controls for any debugging tools.
- Use automated static code analysis tools to identify debug statements.
- Regularly test the application for exposed debug functionality in production.
- Enforce a deployment checklist that ensures no debug code is included.
- Educate developers about the risks of leaving debug code in production.
- Monitor production logs for any accidental exposure of sensitive information.

3. Vulnerability Name: Reliance on Component That is Not Updateable

CWE/CVE: 1329

OWASP/SANS Category: OWASP Top 10 – Software Supply Chain Failures

Description:

This vulnerability occurs when a system depends on a software component, library, or module that cannot be updated or patched. If the component contains security flaws, bugs, or vulnerabilities, the system remains exposed because fixes cannot be applied. Attackers can exploit these known weaknesses to compromise the system, gain unauthorized access, or disrupt operations. Such reliance increases the overall risk posture and limits the organization's ability to respond to emerging threats.

BusinessImpact:

Using components that cannot be updated can have serious consequences for a business. It increases the risk of security breaches, which may lead to financial loss, theft of sensitive data, or operational downtime. Organizations may face regulatory penalties for non-compliance with data protection standards. Persistent vulnerabilities can damage customer trust, harm reputation, and reduce competitiveness in the market, as critical flaws cannot be mitigated over time.



Knowing the weaknesses that result in vulnerabilities means software developers, hardware designers, and security architects can eliminate them before deployment, when it is much easier and cheaper to do so

Learn About CWE		
Overview – Learn what CWE is and how to use the information available on this website		Root Cause Mapping – Learn about identifying the underlying cause(s) of a vulnerability
Basics FAQs Glossary		Guidance Quick Tips Examples
Access Content	Contribute	Latest News and Updates
All Weaknesses (944 total) Top-N Lists Search CWE ENHANCED BY Google View CWEs by	Contribute CWE Content Participate in Working Groups	News "2025 CWE Top 10 KEV Weaknesses" List Now Available News "2025 CWE Top 25 Weaknesses "On the Cusp" List Now Available News CWE Version 4.19.1 Now Available News "2025 CWE™ Top 25" Now Available!

Recommendation/Mitigation:

- Replace non-updateable components with actively maintained alternatives.
- Use components from vendors that provide regular updates and patches.
- Apply compensating controls if replacement isn't immediately possible (e.g., access restrictions, monitoring).
- Continuously monitor for vulnerabilities in third-party components.
- Use automated dependency management tools.
- Implement a patch management policy for updateable components.
- Limit exposure of sensitive data in systems using unpatchable components.
- Conduct regular code reviews to identify outdated or unmaintained components.
- Document risks associated with non-updateable components for management.
- Develop a roadmap to phase out non-updateable components over time.

4. Vulnerability Name: Key Exchange without Entity Authentication

CWE/CVE: CWE-322

OWASP/SANS Category: OWASP Top 10 – Cryptographic Failures

Description:

Key exchange without entity authentication occurs when two parties establish a cryptographic key (used to encrypt communication) without verifying each other's identity. In such cases, the system can agree on a shared secret, but it cannot be sure who it is communicating with. This makes the communication vulnerable to man-in-the-middle attacks, where an attacker can intercept or modify data without either party knowing.

Business Impact:

When key exchange occurs without verifying the identity of the communicating parties, the organization faces significant security risks. Sensitive information, such as research data, financial records, or personal details, can be intercepted or manipulated by attackers through man-in-the-middle attacks. This can lead to unauthorized access to critical systems, data breaches, and operational disruptions. Additionally, such vulnerabilities can damage the organization's reputation and erode trust among students, staff, and partners.

**Common Weakness Enumeration**
A community-developed list of SW & HW weaknesses that can become vulnerabilities

**New to CWE?**
[Start here!](#)

ID Lookup: [Go](#)

[Home](#) | [About](#) | [Learn](#) | [Access Content](#) | [Community](#) | [Search](#)

 Knowing the weaknesses that result in vulnerabilities means software developers, hardware designers, and security architects can eliminate them before deployment, when it is much easier and cheaper to do so

Learn About CWE

Overview – Learn what CWE is and how to use the information available on this website

[Basics](#)
[FAQs](#)
[Glossary](#)

Root Cause Mapping – Learn about identifying the underlying cause(s) of a vulnerability

[Guidance](#)
[Quick Tips](#)
[Examples](#)

Access Content	Contribute	Latest News and Updates
All Weaknesses (944 total) Top-N Lists Search CWE ENHANCED BY Google View CWEs by		

| [Contribute CWE Content](#) [Participate in Working Groups](#) | | [News "2025 CWE Top 10 KEV Weaknesses" List Now Available](#) [News "2025 CWE Top 25 Weaknesses "On the Cusp" List Now Available](#) [News CWE Version 4.19.1 Now Available](#) [News "2025 CWE™ Top 25" Now Available!](#) |

Recommendation:

- Always verify the identity of both parties before exchanging cryptographic keys.
- Implement mutual authentication using digital certificates or identity provider verification.
- Use Public Key Infrastructure (PKI) to issue and manage trusted certificates.
- Apply strong encryption protocols, such as TLS 1.2 or TLS 1.3, for key exchange.
- Conduct regular security audits to identify weaknesses in key exchange processes.
- Monitor for suspicious activity, including unusual login attempts or unauthorized access patterns.
- Ensure compliance with security standards (e.g., GDPR, ISO 27001) during key exchange operations.

5. Vulnerability Name: UNIX Symbolic Link (Symlink) Following

CWE: CWE-59: Improper Link Resolution Before File Access

OWASP Category: A5:2021 – Security Misconfiguration / A01:2021 – Broken Access Control

Description:

This vulnerability occurs when an application improperly follows symbolic links (symlinks) in a UNIX or Linux environment. Attackers can create malicious symlinks pointing to sensitive files or directories, tricking the application into accessing, modifying, or deleting files that should be protected. This can lead to unauthorized access, data corruption, or disclosure of confidential information. The risk is particularly high for applications that run with elevated privileges or handle file uploads, temporary files, or configuration files without proper validation.

Business Impact:

Exploitation of symlink following can have severe consequences for an organization. Attackers may gain access to sensitive system files, user data, or configuration files, leading to data breaches, operational disruption, or loss of system integrity. This can result in financial losses, reputational damage, and potential regulatory non-compliance. If system files are altered or deleted, it may also cause downtime or instability in critical business applications.

The screenshot shows the homepage of the Common Weakness Enumeration (CWE) website. The header features the CWE logo, the text "Common Weakness Enumeration", and a tagline "A community-developed list of SW & HW weaknesses that can become vulnerabilities". On the right, there are two circular badges: "Top 25" and "Top HW CWE", along with a "New to CWE? Start here!" link. Below the header is a navigation bar with links: Home, About, Learn, Access Content, Community, and Search. A search bar is also present. The main content area is divided into several sections. On the left, there's a "Learn About CWE" section with links to Overview, Basics, FAQs, and Glossary. In the center, there's a "Contribute" section with links to "Contribute CWE Content" and "Participate in Working Groups". On the right, there's a "Latest News and Updates" section with several news items, including "2025 CWE Top 10 KEV Weaknesses", "2025 CWE Top 25 Weaknesses", and "CWE Version 4.19.1". At the bottom, there's an "Access Content" section with a search bar and a "View CWE by" link.

Recommendation:

- Validate and sanitize all file paths before accessing files.
- Avoid following symbolic links when handling untrusted input.
- Use secure file access functions that prevent symlink traversal (e.g., `O_NOFOLLOW` flag in Linux).
- Implement proper access controls to limit privileges of applications handling files.
- Isolate temporary and user-uploaded files in dedicated directories.
- Regularly scan file systems for unauthorized symlinks.
- Conduct code reviews focusing on file handling operations.
- Educate developers on safe file handling practices.
- Monitor logs for suspicious file access patterns.
- Apply the principle of least privilege for all file-handling processes.

6. Vulnerability Name: Windows Hard Link Following

CWE:CWE-59: Improper Link Resolution Before File Access

OWASP Category: A5:2021 – Security Misconfiguration / A01:2021 – Broken Access Control

Description:

This vulnerability occurs when an application running on Windows improperly follows hard links. Attackers can create malicious hard links pointing to sensitive files or directories, tricking the application into reading, modifying, or deleting files that should be protected. Applications that run with elevated privileges or handle file uploads, temporary files, or configuration files are particularly at risk. Improper handling of hard links can lead to unauthorized access, data modification, or disclosure of confidential information.

BusinessImpact:

Exploitation of hard link following can result in unauthorized access to sensitive files, deletion or corruption of critical system or user data, and operational disruption. Organizations may face financial losses, reputational damage, and potential regulatory penalties. If system or configuration files are modified or deleted, it can cause downtime or instability in business-critical applications, impacting productivity and service delivery.



Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25

Top HW CWE

New to CWE?
[Start here!](#)

Home | About | Learn | Access Content | Community | Search

ID Lookup:



Knowing the weaknesses that result in vulnerabilities means software developers, hardware designers, and security architects can eliminate them before deployment, when it is much easier and cheaper to do so

Learn About CWE

Overview – Learn what CWE is and how to use the information available on this website

Basics

FAQs

Glossary

Root Cause Mapping – Learn about identifying the underlying cause(s) of a vulnerability

Guidance

Quick Tips

Examples

Access Content

All Weaknesses (944 total)

Top-N Lists

Search CWE

ENHANCED BY Google

View CWEs by

Contribute

Contribute CWE Content

Participate in Working Groups

Latest News and Updates

News "2025 CWE Top 10 KEV Weaknesses" List Now Available

News "2025 CWE Top 25 Weaknesses "On the Cusp" List Now Available

News CWE Version 4.19.1 Now Available

News "2025 CWE™ Top 25" Now Available!

Recommendation :

- Validate and sanitize all file paths before accessing files.
- Avoid following hard links when processing untrusted input.
- Use secure file access APIs that prevent hard link traversal.
- Apply proper access controls and run applications with the least privilege necessary.
- Isolate temporary and user-uploaded files in dedicated directories.
- Regularly monitor file systems for suspicious or unexpected hard links.
- Conduct code reviews for all file-handling routines.
- Educate developers about safe file handling practices in Windows.
- Log and monitor file access operations for anomalies.
- Implement file integrity monitoring to detect unauthorized changes.

7. Vulnerability Name: Exposure of Sensitive Information to an Unauthorized Actor

CWE: CWE-200: Exposure of Sensitive Information to an Unauthorized Actor **OWASP**

Category: A03:2021 – Sensitive Data Exposure

Description:

This vulnerability occurs when sensitive information is accessible to users, systems, or applications without proper authorization. Such information can include personal data, credentials, financial records, or proprietary business information. Attackers can exploit this flaw to access, copy, or misuse confidential data. Causes often include misconfigured access controls, weak authentication, unencrypted data storage or transmission, and inadequate input validation. Exposure of sensitive information can compromise user privacy, system integrity, and overall organizational security.

business Impact:

Unauthorized exposure of sensitive information can lead to data breaches, financial loss, and reputational damage. Organizations may face regulatory penalties for non-compliance with data protection laws. Customer trust can be eroded, and leaked information may be used for identity theft, fraud, or further targeted attacks. Additionally, exposure of proprietary business data can reduce competitiveness and threaten long-term operational stability.



Knowing the weaknesses that result in vulnerabilities means software developers, hardware designers, and security architects can eliminate them before deployment, when it is much easier and cheaper to do so

Learn About CWE		
Overview – Learn what CWE is and how to use the information available on this website		Root Cause Mapping – Learn about identifying the underlying cause(s) of a vulnerability
Basics FAQs Glossary		Guidance Quick Tips Examples
Access Content	Contribute	Latest News and Updates
All Weaknesses (944 total) Top-N Lists Search CWE ENHANCED BY Google View CWEs by	Contribute CWE Content Participate in Working Groups	News "2025 CWE Top 10 KEV Weaknesses" List Now Available News "2025 CWE Top 25 Weaknesses "On the Cusp" List Now Available News CWE Version 4.19.1 Now Available News "2025 CWE™ Top 25" Now Available!

Recommendation:

- Implement strict access controls and enforce role-based permissions.
- Encrypt sensitive data both at rest and in transit.
- Regularly audit user access and system permissions.
- Use strong authentication mechanisms, including multi-factor authentication.
- Sanitize and validate all inputs to prevent accidental disclosure.
- Monitor logs for unauthorized access attempts or unusual activity.
- Educate employees and administrators on secure handling of sensitive data.
- Remove sensitive information from non-secure locations, such as temporary files.
- Apply the principle of least privilege for all users and processes.
- Conduct regular security testing to identify and remediate information exposure risks.

8. Vulnerability Name: Exposure of Sensitive Information Through Sent Data

CWE: CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

OWASP Category: A03:2021 – Sensitive Data Exposure **Description:**

This vulnerability occurs when sensitive information is exposed during transmission over networks, allowing unauthorized actors to intercept, read, or manipulate the data. Sensitive information can include credentials, personal data, financial details, or proprietary business information. Common causes include unencrypted communication channels, weak encryption protocols, insecure APIs, and improper handling of data in transit. Attackers can exploit these weaknesses to compromise confidentiality, integrity, or privacy of the transmitted information.

Business Impact:

Exposure of sensitive data during transmission can lead to identity theft, financial loss, regulatory penalties, and reputational damage. Intercepted data may be used to launch further attacks, gain unauthorized system access, or exploit customers. Organizations risk non-compliance with data protection regulations (e.g., GDPR, HIPAA) and may face legal consequences. Loss of trust from customers or partners can negatively impact business operations and long-term competitiveness.



Knowing the weaknesses that result in vulnerabilities means software developers, hardware designers, and security architects can eliminate them before deployment, when it is much easier and cheaper to do so

Learn About CWE		
Overview – Learn what CWE is and how to use the information available on this website		Root Cause Mapping – Learn about identifying the underlying cause(s) of a vulnerability
Basics FAQs Glossary		Guidance Quick Tips Examples
Access Content	Contribute	Latest News and Updates
All Weaknesses (944 total) Top-N Lists Search CWE ENHANCED BY View CWEs by	Contribute CWE Content Participate in Working Groups	News "2025 CWE Top 10 KEV Weaknesses" List Now Available News "2025 CWE Top 25 Weaknesses "On the Cusp" List Now Available News CWE Version 4.19.1 Now Available News "2025 CWE™ Top 25" Now Available!

Recommendation :

- Encrypt all sensitive data in transit using strong protocols (e.g., TLS 1.2 or higher).
- Avoid transmitting sensitive data over untrusted or public networks.
- Use secure APIs and enforce proper authentication and authorization.
- Validate and sanitize all outgoing data to prevent accidental leakage.
- Implement network monitoring to detect unauthorized data interception attempts.
- Educate employees about secure communication practices.
- Apply strict access control policies to systems handling sensitive transmissions.
- Rotate encryption keys and certificates regularly.
- Conduct regular security testing of network communication channels.
- Use end-to-end encryption where possible to ensure confidentiality.

9. VulnerabilityName: Storage of File with Sensitive Data Under Web Root

CWE: CWE-532: Insertion of Sensitive Information into Log File or Web Accessible Location

OWASPCategory: A03:2021 – Sensitive Data Exposure

Description:

This vulnerability occurs when sensitive files, such as configuration files, credentials, or user data, are stored under the web root directory, making them directly accessible via a web browser. Attackers can easily locate and download these files, leading to exposure of sensitive information. Common causes include improper file storage practices, misconfigured web servers, and lack of separation between application data and public-facing directories. Exploitation can compromise confidentiality, integrity, and security of the application and its users.

Business Impact:

If sensitive files are accessible under the web root, attackers may gain credentials, access configuration details, or obtain confidential data, leading to data breaches, system compromise, and operational disruption. Organizations may face financial losses, legal penalties for non-compliance with data protection regulations, and significant reputational damage. Exposure of critical business or user data can reduce customer trust and impact the organization's long-term competitiveness.



Knowing the weaknesses that result in vulnerabilities means software developers, hardware designers, and security architects can eliminate them before deployment, when it is much easier and cheaper to do so

Learn About CWE		
Overview – Learn what CWE is and how to use the information available on this website		Root Cause Mapping – Learn about identifying the underlying cause(s) of a vulnerability
Basics FAQs Glossary		Guidance Quick Tips Examples
Access Content	Contribute	Latest News and Updates
All Weaknesses (944 total) Top-N Lists Search CWE ENHANCED BY View CWEs by	Contribute CWE Content Participate in Working Groups	News "2025 CWE Top 10 KEV Weaknesses" List Now Available News "2025 CWE Top 25 Weaknesses "On the Cusp" List Now Available News CWE Version 4.19.1 Now Available News "2025 CWE™ Top 25" Now Available!

Recommendation:

- Store sensitive files outside of the web root directory.
- Apply strict access controls to directories containing sensitive data.
- Configure web servers to deny direct access to sensitive files.
- Encrypt sensitive files both at rest and in transit.
- Regularly audit file storage locations for sensitive content.
- Implement secure file upload handling with proper validation.
- Educate developers on safe file storage practices.
- Use logging and monitoring to detect unauthorized access attempts.
- Remove any legacy files containing sensitive information from web-accessible locations.
- Conduct regular penetration testing to identify exposed sensitive files.

CWE: CWE-276: Incorrect Default Permissions

OWASPCategory: A05:2021 – Security Misconfiguration

Description:

This vulnerability occurs when files, directories, or system resources are deployed with default permissions that are too permissive, granting unauthorized users access to sensitive data or functionality. Attackers can exploit overly permissive defaults to read, modify, or delete critical files, escalate privileges, or gain unauthorized access to system components. Causes often include lack of secure configuration during installation, inadequate hardening procedures, or failure to adjust default settings provided by software vendors.

businessImpact:

Incorrect default permissions can lead to unauthorized access to sensitive information, system compromise, data corruption, or operational disruption. Exploitation may result in financial losses, regulatory penalties, and reputational damage. Additionally, overly permissive access may allow attackers to move laterally within the organization's network, increasing the potential impact of a security breach and threatening long-term system integrity.



Knowing the weaknesses that result in vulnerabilities means software developers, hardware designers, and security architects can eliminate them before deployment, when it is much easier and cheaper to do so

Learn About CWE		
Overview – Learn what CWE is and how to use the information available on this website		Root Cause Mapping – Learn about identifying the underlying cause(s) of a vulnerability
Basics FAQs Glossary		Guidance Quick Tips Examples
Access Content	Contribute	Latest News and Updates
All Weaknesses (944 total) Top-N Lists Search CWE ENHANCED BY  View CWEs by	Contribute CWE Content Participate in Working Groups	News "2025 CWE Top 10 KEV Weaknesses" List Now Available News "2025 CWE Top 25 Weaknesses "On the Cusp" List Now Available News CWE Version 4.19.1 Now Available News "2025 CWE™ Top 25" Now Available!

Recommendation:

1. Review and adjust default permissions for all files, directories, and system resources.
2. Apply the principle of least privilege to restrict access to only necessary users and processes.
3. Implement secure configuration guidelines during installation or deployment.
4. Regularly audit permissions to ensure they remain appropriate over time.
5. Use automated configuration management tools to enforce correct permissions.
6. Educate administrators and developers on secure permission practices.
7. Disable or remove unnecessary accounts and services.
8. Monitor logs for unauthorized access attempts to sensitive files or directories.
9. Harden systems according to vendor and industry security recommendations.
10. Conduct periodic penetration testing to identify misconfigured permissions.

Stage 2

Overview – What I understood about Nessus

Nessus is a widely used vulnerability assessment tool developed by Tenable that helps security professionals identify weaknesses in systems, networks, and web applications. The tool scans a target system and analyzes services, configurations, and protocols running on it. Nessus performs remote scanning by sending specially crafted requests to detect potential security flaws. A major feature of Nessus is its plugin-based architecture.

Each plugin identifies a specific vulnerability or configuration issue such as outdated encryption protocols, weak cipher suites, exposed services, or misconfigured security settings. During a scan, Nessus gathers information about the target system including open ports, operating system details, and running services. Then it launches relevant plugins to check for known vulnerabilities.

Nessus can scan individual machines, enterprise networks, cloud environments, and web applications. Security teams use it to perform regular vulnerability assessments to identify security weaknesses before attackers exploit them. The generated reports categorize vulnerabilities based on severity levels such as informational, low, medium, and high. The reports also provide detailed explanations and recommended solutions so administrators can fix issues effectively.

By performing regular scans and addressing the findings, organizations can improve their cybersecurity posture and reduce the risk of cyber attacks.

Target Details

Target Website	http://testfire.net/
Target IP Address	65.61.137.117

List of Vulnerabilities

S.No	Vulnerability Name	Severity	Plugin
1	TLS Version 1.0 Protocol Detection	Medium	104743
2	TLS Version 1.1 Protocol Deprecated	Medium	157288
3	SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits (Logjam)	Low	83875
4	ICMP Timestamp Request Remote Date Disclosure	Info	10114
5	Additional DNS Hostnames Detected	Info	46180
6	Apache Tomcat Detection	Info	39446
7	Common Platform Enumeration (CPE)	Info	45590

8	Device Type Detection	Info	54615
9	HSTS Missing from HTTPS Server	Info	84502
10	HTTP Server Type and Version Disclosure	Info	10107

Reports

Vulnerability Name: TLS Version 1.0 Protocol Detection

Severity: Medium

Plugin: 104743

Port: 443

Description: The remote server supports Transport Layer Security (TLS) version 1.0, which is considered an outdated and insecure cryptographic protocol. TLS 1.0 was designed to provide secure communication between clients and servers by encrypting transmitted data. However, due to several design weaknesses and the evolution of modern attack techniques, TLS 1.0 is no longer considered safe for protecting sensitive information.

Security researchers have identified multiple vulnerabilities that can potentially be exploited when TLS 1.0 is enabled. These weaknesses may allow attackers to perform cryptographic attacks such as protocol downgrade attacks or exploit flaws in the encryption process. In some cases, attackers positioned between the client and the server may attempt to intercept or manipulate encrypted traffic.

Solution: Disable TLS 1.0 and enable TLS 1.2 or TLS 1.3 in server configuration.

Business Impact: Using outdated encryption protocols such as TLS 1.0 can significantly increase the risk of sensitive data being exposed during communication between the client and the server. Attackers may exploit known weaknesses in older encryption standards to intercept, decrypt, or manipulate transmitted information. This could lead to the disclosure of confidential data such as login credentials, personal information, or financial details.

In addition, continuing to use deprecated security protocols may result in non-compliance with modern cybersecurity standards and regulations such as PCI-DSS and other industry security guidelines.

Vulnerability Name: TLS Version 1.1 Protocol Deprecated

Severity: Medium

Plugin: 157288

Port: 443

Description: The remote server allows encrypted connections using Transport Layer Security (TLS) version 1.1, which is now considered obsolete and no longer recommended for secure communications. TLS 1.1 was introduced as an improvement over TLS 1.0, but it still lacks many of the modern security protections available in newer encryption protocols.

Over time, security researchers have discovered limitations and weaknesses in TLS 1.1 that could potentially be exploited by attackers.

Although TLS 1.1 provides encryption for data transmitted between the client and the server, it does not support several advanced cryptographic features that improve protection against modern cyber threats. Because of these limitations, most modern browsers, operating systems, and security frameworks have deprecated support for TLS 1.1 and encourage the use of stronger protocols such as TLS 1.2 or TLS 1.3.

Solution: Disable TLS 1.1 and use modern encryption protocols.

Business Impact: Deprecated protocols increase risk of interception and compatibility issues.

Vulnerability Name: SSL/TLS Diffie-Hellman Modulus $\leq$ 1024 Bits (Logjam)

Severity: Low

Plugin: 83875

Port: 443

Description: The server supports weak Diffie-Hellman (DH) key exchange parameters, typically using a modulus size of 1024 bits or smaller. Diffie-Hellman is a cryptographic algorithm used in SSL/TLS protocols to securely exchange encryption keys between the client and the server. However, when weak parameters are used, the strength of the encryption process is significantly reduced.

Small Diffie-Hellman key sizes can make the encryption vulnerable to certain cryptographic attacks. One well-known example is the Logjam attack, where attackers may exploit weak DH parameters to downgrade the encryption strength and potentially decrypt secure communications. With sufficient computing power, attackers may be able to break the encryption and gain access to sensitive data transmitted between the client and the server.

Solution: Configure stronger 2048 bit or higher DH parameters.

Business Impact: Weak encryption mechanisms can make secure communications vulnerable to compromise by attackers. If the encryption strength is insufficient, attackers may be able to exploit cryptographic weaknesses to intercept, analyze, or decrypt sensitive information transmitted between the client and the server. This could expose confidential data such as authentication credentials, personal information, or financial details.

In addition, weak encryption can allow attackers to perform man-in-the-middle (MITM) attacks, where they secretly intercept and potentially modify communication between two parties without their knowledge. Such attacks can lead to unauthorized access to systems, data manipulation, or session hijacking.

Vulnerability Name: ICMP Timestamp Request Remote Date Disclosure

Severity: Info

Plugin: 10114

Port: 0

Description: The remote system responds to ICMP Timestamp requests, which allows external users to determine the current system time of the target machine. ICMP (Internet Control Message Protocol) timestamp messages are primarily used for network diagnostics and time synchronization. However, when a system responds to these requests, it reveals information about the internal clock of the server.

Solution: Block ICMP timestamp requests using firewall rules.

Business Impact: Allowing ICMP timestamp responses can provide useful reconnaissance information to attackers during the early stages of an attack. By obtaining the system's current time and related information, attackers can gain insights into the target system's configuration and behavior.

Vulnerability Name: Apache Tomcat Detection

Severity: Info

Plugin: 39446

Port: 80

Description: The vulnerability scan detected that the target system is running the Apache Tomcat web application server. Apache Tomcat is an open-source software implementation of Java Servlet, JavaServer Pages (JSP), and other Java technologies used to host and run web-based applications. It is commonly used by organizations to deploy Java-based web services and enterprise applications.

Solution: Ensure the software is updated and securely configured.

Business Impact: If attackers identify that the server is running Apache Tomcat, they may attempt to exploit known vulnerabilities associated with that software or its specific version. Public vulnerability databases often contain detailed information about security flaws affecting different Tomcat versions. Attackers can use this information to launch targeted attacks against systems that have not been properly updated or secured.

Vulnerability Name: Common Platform Enumeration (CPE)

Severity: Info

Plugin: 45590

Port: 0

Description: The vulnerability scan identified system components and mapped them to Common Platform Enumeration (CPE) identifiers. CPE is a standardized naming system used to uniquely identify software, operating systems, and hardware platforms. Security tools such as vulnerability scanners use CPE identifiers to accurately classify the technologies running on a system and match them with known vulnerabilities listed in security databases.

Solution: Maintain updated asset inventory and patch management.

Business Impact: Identifying system components through CPE information can provide attackers with useful insights about the technologies and software running on the target system. When attackers know the exact platform, software product, or service in use, they can search public vulnerability databases to find known security weaknesses associated with those components.

Vulnerability Name: Device Type Detection

Severity: Info

Plugin: 54615

Port: 0

Description: The vulnerability scan was able to identify the device type and system category of the target host based on its network behavior, open ports, and response patterns. Vulnerability scanners use various techniques such as service fingerprinting.

Solution: No direct fix required; limit unnecessary system exposure.

Business Impact: If attackers are able to identify the device type and system category, they can use this information to plan more targeted and effective attacks. Knowing whether a system is a web server, database server, network device, or workstation helps attackers focus on vulnerabilities that are specific to that type of system.

Vulnerability Name: HSTS Missing from HTTPS Server

Severity: Info

Plugin: 84502

Port: 443

Description: The scan identified that the HTTPS server does not implement HTTP Strict Transport Security (HSTS). HSTS is a security mechanism that instructs web browsers to always communicate with the server using secure HTTPS connections instead of HTTP. When HSTS is enabled, the server sends a special header to the browser, which forces the browser to use HTTPS for all future requests to that website.

Solution: Enable HTTP Strict Transport Security header.

Business Impact: The absence of HTTP Strict Transport Security (HSTS) can expose users to potential security risks during communication with the web server. Without HSTS enforcement, browsers may initially attempt to connect to the website using an unsecured HTTP connection before switching to HTTPS. During this brief period, attackers on the same network may attempt to intercept or manipulate the communication.

Stage 3

Report

Title: INTEGRATE ZSCALER WITH IDENTITY PROVIDERS (IDPS) SUCH AS AZURE AD, OKTA ,AND ACTIVE DIRECTORY FOR SEAMLESS AUTHENTICATION AND AUTHORIZATION

Security Operations Center (SOC)

A Security Operations Center (SOC) is a centralized unit responsible for monitoring, detecting, and responding to cybersecurity threats within an organization. The SOC team continuously monitors network traffic, system logs, and security events to identify suspicious activities or potential cyberattacks. Security analysts in the SOC analyze alerts, investigate incidents, and take necessary actions to prevent data breaches or system compromises. The main objective of a SOC is to maintain the security of an organization's IT infrastructure and protect sensitive data from cyber threats.

SOC-Cycle

The SOC cycle represents the continuous process of monitoring, detecting, analyzing, and responding to security threats. It begins with monitoring network activities and collecting logs from different devices. After monitoring, potential threats are detected through security alerts. These alerts are then analyzed by security analysts to determine whether they represent real threats. If a threat is confirmed, the response team takes action to contain and eliminate the threat. Finally, recovery and improvement steps are taken to strengthen security measures and prevent similar attacks in the future.

Security Information and Event Management (SIEM)

Security Information and Event Management (SIEM) is a security solution that collects and analyzes log data from various devices and systems within an organization. SIEM tools help security teams detect suspicious activities by correlating logs from different sources such as servers, firewalls, applications, and network devices. It provides a centralized platform where all security events can be monitored in real time. SIEM also generates alerts for unusual activities, helping organizations respond quickly to potential security incidents.

SIEM Cycle

The SIEM cycle begins with collecting log data from various systems such as servers, routers, and applications. The collected logs are then normalized and analyzed to identify patterns or anomalies. Through correlation rules, the SIEM system identifies suspicious events and generates alerts. Security analysts review these alerts and investigate possible threats. If a security incident is confirmed, appropriate response actions are taken. This cycle continues to ensure continuous monitoring and improvement of the organization's cybersecurity system.

Malware Information Sharing Platform (MISP)

Malware Information Sharing Platform (MISP) is an open-source threat intelligence platform that enables organizations to share information about cyber threats and malware attacks. It allows security teams to share indicators of compromise (IOCs), attack patterns, and threat intelligence data with other organizations. This collaborative approach helps improve cybersecurity by providing early warnings about potential threats. MISP helps organizations detect and prevent cyberattacks more effectively through shared knowledge and threat data.

Your College Network Information

The college network consists of multiple computers, servers, routers, and switches connected to provide internet access and internal services to students, faculty, and administrative staff. The network supports academic activities such as online learning, digital libraries, and communication

systems. Security measures such as firewalls, antivirus software, and authentication systems are implemented to protect the network from unauthorized access and cyber threats. The network infrastructure ensures reliable connectivity and data security across the campus.

How You Think You Deploy SOC in Your College

To deploy a Security Operations Center in our college, we would first collect logs from all network devices, servers, and applications. These logs can be integrated into a SIEM system for centralized monitoring. Security analysts would continuously monitor network activities to detect suspicious behavior. Alerts generated by the SIEM tool would help identify possible threats. Additional security tools such as firewalls, intrusion detection systems (IDS), and endpoint protection systems would be integrated to strengthen the security framework. This setup would help protect the college network from cyber threats.

Threat Intelligence

Threat intelligence refers to the collection and analysis of information about current and potential cyber threats. It helps organizations understand attacker behavior, vulnerabilities, and possible attack methods. Threat intelligence includes information about malware, phishing attacks, and hacking techniques. By analyzing this data, security teams can develop strategies to prevent attacks before they occur. It plays an important role in improving an organization's overall cybersecurity posture.

Incident Response

Incident response is the process of identifying, managing, and resolving cybersecurity incidents. It begins with detecting a security incident through monitoring tools or alerts. Once detected, the incident is analyzed to determine its impact and cause. The next step is containment, where actions are taken to prevent the attack from spreading. After containment, systems are recovered and restored to normal operations. Finally, a review is conducted to understand the incident and implement measures to prevent similar incidents in the future.

QRadar & Understanding About the Tool

QRadar is a SIEM solution developed by IBM that helps organizations monitor and analyze security events across their networks. It collects log data from different devices and applications and analyzes it to detect suspicious activities. QRadar uses advanced analytics and correlation rules to identify potential threats and generate alerts. The dashboard provides real-time visibility into network security, allowing security teams to quickly detect and respond to cyber threats.

Conclusion

Stage 1

In Stage 1, we learned about web application security testing. The focus was on identifying vulnerabilities in web applications using different testing methods. We also studied common vulnerabilities and how to prevent them to improve application security.

Stage 2

In Stage 2, we analyzed vulnerability scan reports generated by the Nessus tool. The report helped us understand different security vulnerabilities present in systems and applications. We also learned about the severity levels of vulnerabilities and the recommended remediation steps to fix them.

Stage 3

In Stage 3, we learned about the working of Security Operations Centers, SIEM technology, and the QRadar security monitoring dashboard. This stage helped us understand how organizations monitor network activities, detect cyber threats, and respond to security incidents effectively.

Future Scope:

Stage 1

Web application testing will continue to evolve with the development of new technologies and applications. Future advancements may include automated security testing tools and AI-based vulnerability detection systems.

Stage 2

The testing process will become more advanced with the integration of automated vulnerability scanning and continuous security monitoring. Organizations will adopt advanced tools to identify and fix vulnerabilities more efficiently.

Stage 3

The future of SOC and SIEM will involve the use of artificial intelligence and machine learning to detect cyber threats more accurately. Advanced automation will help security teams respond to incidents faster and improve overall cybersecurity management.

Topics Explored:

- Security Operations Center (SOC)
- SIEM Technology
- Threat Intelligence
- Incident Response
- Network Security Monitoring

Tools Explored:

- QRadar
 - Nessus
 - MISP
 - Zscaler
-

THE END
